Studio Nx

백엔드 160 — POST /auth/password-reset/request

2026-10-14

백엔드 160 — `POST /auth/password-reset/request` (재설정 요청 라우터)

항목	내용
파일	`studionx/backend/app/api/v1/auth.py`의 `password_reset_request()`, 스키마 `app/schemas/auth.py`의 `PasswordResetRequest`, `PasswordResetRequestResponse`
작업	P1-28 비밀번호 찾기 (FR-118): 열한 번째 함수
작성	Claude (AI), 2026-10-15, 사용자 검토
이전	159 `/auth/refresh`
시험	`tests/test_password_reset_service.py`의 13개 추가 (파일 전체 56개), 실제 앱과 실제 MySQL
다음	`POST /auth/password-reset/confirm`: 토큰과 새 비밀번호로 `reset_password()`를 부름

1. 하는 일

로그인 없이 부르는 API입니다. 이메일 하나를 받아 `request_password_reset()`(154번)을 부르고, **가입 여부와 관계없이 항상 같은 응답**을 돌려줍니다.

```
POST /api/v1/auth/password-reset/request
{ "email": "you@example.com" }

→ 202 Accepted
{ "message": "If an account exists for that email, we've sent a message." }
```

결과	언제
202 + 고정 본문	형식이 맞는 모든 요청 (가입된 주소, 없는 주소, 탈퇴, 정지 계정 모두 같음)
422 `VALIDATION_ERROR`	이메일 형식이 틀림, 본문이 없음
429 `TOO_MANY_REQUESTS` + `details.retry_after`	요청이 잦음 (가입 여부와 무관하게 셈)

오류는 이 둘뿐이고, 둘 다 가입 여부와 상관없는 이유로만 납니다.

2. 코드

```
class PasswordResetRequest(BaseModel):
    email: EmailStr = Field(max_length=255)

class PasswordResetRequestResponse(BaseModel):
    message: str

PASSWORD_RESET_REQUEST_MESSAGE = "If an account exists for that email, we've sent a message."

@router.post("/password-reset/request", response_model=PasswordResetRequestResponse,
             status_code=status.HTTP_202_ACCEPTED,
             responses={422: {"model": ErrorResponse}, 429: {"model": ErrorResponse}})
def password_reset_request(data: PasswordResetRequest, request: Request, db: Db):
```

```
    password_reset_service.request_password_reset(db, data.email, client_ip(request))
    return PasswordResetRequestResponse(message=PASSWORD_RESET_REQUEST_MESSAGE)
```

3. 왜 이렇게

선택	이유
상태 코드 202 (Accepted)	"요청을 받았다"는 뜻입니다. 메일이 실제로 가는지는 가입 여부에 달려 있고 그것을 알리지 않으므로, 200(성공)이나 201(만들었다)보다 정확합니다
고정 문구	`If an account exists…`는 "있다면 보냈다"는 조건문이라 사실을 드러내지 않습니다. 본문과 응답 길이까지 같습니다(시험으로 확인)
이메일 형식만 검사 (`EmailStr`)	형식 오류(422)는 가입 여부와 무관하게 입력만 보고 나는 오류라 새는 정보가 없습니다. 가입 때와 같은 검사입니다
IP는 문의 라우터의 `client_ip()`를 가져다 씀	같은 규칙(프록시 뒤에서만 `X-Forwarded-For`를 믿음)을 복사하지 않고 한 곳에서 관리합니다. 프록시 설정은 `TRUST_PROXY` 하나로 함께 바뀝니다
응답에 이메일과 토큰을 넣지 않음	응답은 로그, 프록시, 브라우저 기록에 남을 수 있습니다

4. 시험 (13개 추가, 파일 전체 56개 통과)

확인	결과
경로가 등록되고 202, 429가 문서에 있음	✓
가입된 계정은 202 + 고정 본문이고 토큰이 저장됨	✓
없는 계정이 가입된 계정과 똑같은 응답(상태, 본문, `content-length`, 쿠키 없음)	✓
탈퇴, 정지 계정도 같은 응답이고 토큰은 만들지 않음	✓ ✓
이메일 대소문자와 공백을 정리한 뒤 찾음	✓
형식이 틀린 이메일 5종은 422	✓ (5개)
본문이 비었거나 없으면 422	✓
가입 여부와 관계없이 4번째 요청이 429(`retry_after` 포함)	✓
같은 IP에서 서로 다른 이메일 11번째가 429(이메일 한도와 별개의 IP 한도)	✓
로그인 없이 호출됨	✓
응답에 토큰과 이메일이 들어 있지 않음	✓

시험을 확인하는 시험. 일부러 틀리게 바꿔 시험이 잡는지 보았습니다.

바꾼 것	결과
상태 코드를 200으로	8개 실패
가입되지 않은 주소에만 다른 본문("No such account.")	1개 실패
IP 대신 `None`을 넘김	**처음에는 실패 없음**, 시험을 보강한 뒤 1개 실패
횟수 제한 제거	2개 실패
가입되지 않은 주소에서 404	4개 실패

시험을 보강한 일. "IP 대신 `None`을 넘기는" 실수를 처음에는 시험이 잡지 못했습니다. 이메일 한도(3번)는 라우터를 거쳐 시험했지만 IP 한도(10번)는 서비스 함수로만 시험했기 때문입니다. 라우터가 IP를 제대로 넘기지 않으면

IP 한도가 조용히 꺼지는 위험한 빈틈이어서, 라우터를 거쳐 11번째 요청을 확인하는 시험을 더했습니다. 보강 뒤에는 같은 변이를 잡습니다.

전체 pytest 801개 통과, `ruff` 통과.

5. 알아 둔 한계: 응답 시간

응답 내용은 같지만 **걸리는 시간**은 다를 수 있습니다. 가입된 계정은 토큰 저장(DB 쓰기)과 로그 출력을 하고, 없는 계정은 조회만 하고 끝나서 몇 밀리초 빠릅니다. 아주 많은 요청을 정밀하게 재면 가입 여부를 추측할 수 있지만, 이 API는 이메일당 10분에 3번, IP당 10번으로 제한되어 통계를 낼 만큼 부를 수 없습니다. 실제 메일(SMTP)을 붙이면 시간 차가 훨씬 커지므로, 그때 **메일 발송을 응답 뒤의 백그라운드 작업**으로 옮겨야 합니다. 배포 전 할 일로 남겨 둡니다.